



ЦЕЛЕНАПРАВЛЕННЫЕ АТАКИ

ПРАКТИЧЕСКОЕ ЗАДАНИЕ: ОПРЕДЕЛЕНИЕ АКТУАЛЬНЫХ УГРОЗ ПО МЕТОДОЛОГИИ ФСТЭК РОССИИ

Выполнил: Юрий Шамрай (MIFIIB/1-й поток)

ЦЕЛЬ ПРАКТИЧЕСКОГО ЗАДАНИЯ:

Определить актуальные угрозы безопасности информации.

ЧТО НУЖНО СДЕЛАТЬ:

- На основе данных об организации:
 - ✓ Продумать сценарии реализации угроз безопасности информации по методологии ФСТЭК России;
 - ✓ Выделить угрозы из БДУ ФСТЭК, которые реализуются благодаря этому сценарию;
 - ✓ Предоставьте ответ в таблице.

УСЛОВИЯ ЗАДАЧИ:

Дана коммерческая организаций, которая занимается грузоперевозками. В организации есть несколько отделов:

- Менеджеры по грузоперевозкам;
- Бухгалтерия;
- Кадровая служба;
- Служба ИТ.

Дополнительная информация, которая вам известна:

- Есть сайт, размещённый на собственных мощностях;
- DMZ-зона отсутствует;
- Сотрудников с удалённым доступом нет;
- Менеджеры звонят с использование IP-телефонии.

ВВЕДЕНИЕ

В рамках данного практического задания нам предстоит определить актуальные угрозы безопасности информации для коммерческой организации, занимающейся грузоперевозками. Для этого мы воспользуемся методологией Федеральной службы технического и экспортного контроля Российской Федерации (ФСТЭК России) и проанализируем сценарии реализации угроз, которые могут повлиять на безопасность информации в данной организации.

Цель данного задания - продумать и идентифицировать угрозы безопасности информации, специфичные для организации, а также выделить соответствующие угрозы из базы данных угроз ФСТЭК России.

Условия задачи предоставляют информацию о структуре организации и некоторых характеристиках ее информационной системы. Для выполнения задания нам доступны следующие данные: организация занимается грузоперевозками, имеет несколько отделов, включая менеджеров по грузоперевозкам, бухгалтерию, кадровую службу и службу информационных технологий. Организация имеет свой веб-сайт, размещенный на собственных мощностях, отсутствует DMZ-зона, а также сотрудники с удаленным доступом.

ВЫПОЛНЕНИЕ

Далее мы рассмотрим сценарии реализации угроз безопасности информации согласно методологии ФСТЭК России и выделим угрозы из базы данных ФСТЭК, которые могут быть актуальными для данной организации:

1. УБИ.098: Угроза обнаружения открытых портов и идентификации привязанных к ним сетевых служб:

Угроза заключается в возможности определения нарушителем состояния сетевых портов дискредитируемой системы (т.н. сканирование портов) для получения сведений о возможности установления соединения с дискредитируемой системой по данным портам, конфигурации самой системы и установленных средств защиты информации, а также других сведений, позволяющих нарушителю определить по каким портам деструктивные программные воздействия могут быть осуществлены напрямую, а по каким – только с использованием специальных техник обхода межсетевых экранов.

T1: Сбор информации о системах и сетях:

Тактическая задача: нарушитель стремится получить любую техническую информацию, которая может оказаться полезной в ходе реализации угроз безопасности информации.

- **T1.3:** Пассивный сбор (прослушивание) информации о подключенных к сети устройствах с целью идентификации сетевых служб, типов и версий ПО этих служб и в некоторых случаях – идентификации информации пользователей;
- **T1.4:** Направленное сканирование при помощи специализированного программного обеспечения подключенных к сети устройств с целью идентификации сетевых сервисов, типов и версий программного обеспечения этих сервисов, а также с целью получения конфигурационной информации компонентов систем и сетей, программного обеспечения сервисов и приложений (сканирование при помощи сканера nmap).

2. УБИ.073: Угроза несанкционированного доступа к активному и (или) пассивному виртуальному и (или) физическому сетевому оборудованию из физической и (или) виртуальной сети:

Угроза заключается в возможности изменения вредоносными программами алгоритма работы программного обеспечения сетевого оборудования и (или) параметров его настройки путём эксплуатации уязвимостей программного и (или) микропрограммного обеспечения указанного оборудования.

3. УБИ.030: Угроза использования информации идентификации/аутентификации, заданной по умолчанию:

Угроза заключается в возможности прохождения нарушителем процедуры авторизации на основе полученной из открытых источников или от информационного сервиса идентификационной и аутентификационной информации, соответствующей учётной записи «по умолчанию» дискредитируемого объекта защиты.

4. УБИ.192: Угроза использования уязвимых версий программного обеспечения:

Угроза заключается в возможности осуществления нарушителем деструктивного воздействия на систему путём эксплуатации уязвимостей программного обеспечения.

T2: Получение первоначального доступа к компонентам систем и сетей:

Тактическая задача: нарушитель, находясь вне инфраструктуры сети или системы, стремится получить доступ к любому узлу в инфраструктуре и использовать его как плацдарм для дальнейших действий.

- **T2.1:** Использование внешних сервисов организации в сетях публичного доступа (Интернет): доступ к веб-серверу, расположенному в сети организации; доступ к интерфейсу электронной почты Outlook Web Access (OWA) почтового сервера организации;
- **T2.3:** Эксплуатация уязвимостей сетевого оборудования и средств защиты вычислительных сетей для получения доступа к компонентам систем и сетей при удаленной атаке (обход межсетевого экрана путем эксплуатации уязвимостей реализации правил фильтрации);
- **T2.4:** Использование ошибок конфигурации сетевого оборудования и средств защиты, в том числе слабых паролей и паролей по умолчанию, для получения доступа к компонентам систем и сетей при удаленной атаке;
- **T2.5:** Эксплуатация уязвимостей компонентов систем и сетей при удаленной или локальной атаке (эксплуатация уязвимостей веб-сервера с целью выполнения произвольного кода в контексте этого сервера);
- **T2.8:** Использование методов социальной инженерии, в том числе фишинга, для получения прав доступа к компонентам системы;
- **T2.10:** Несанкционированный доступ путем подбора учетных данных сотрудника или легитимного пользователя (методами прямого перебора, словарных атак, паролей производителей по умолчанию, использования одинаковых паролей для разных учетных записей, применения «радужных» таблиц или другими).

5. УБИ.006: Угроза внедрения кода или данных:

Угроза заключается в возможности внедрения нарушителем в дискредитируемую информационную систему или устройство вредоносного кода, который может быть в дальнейшем запущен «вручную» пользователями, автоматически при выполнении определённого условия (наступления определённой даты, входа пользователя в систему и т.п.) или с использованием аутентификационных данных, заданных «по умолчанию», а также в возможности несанкционированного внедрения нарушителем некоторых собственных данных для обработки в дискредитируемую информационную систему, фактически осуществив незаконное использование чужих вычислительных ресурсов, и блокирования работы устройства при выполнении определенных команд.

T3: Внедрение и исполнение вредоносного программного обеспечения в системах и сетях.

Тактическая задача: получив доступ к узлу сети или системы, нарушитель стремится внедрить в его программную среду инструментальные средства, необходимые ему для дальнейших действий.

- **T3.1:** Автоматический запуск скриптов и исполняемых файлов в системе с использованием пользовательских или системных учетных данных, в том числе с использованием методов социальной инженерии;
- **T3.2:** Активация и выполнение вредоносного кода, внедренного в виде закладок в легитимное программное и программное-аппаратное обеспечение систем и сетей;
- **T3.4:** Копирование и запуск скриптов и исполняемых файлов через средства удаленного управления операционной системой и сервисами;

6. УБИ.008: Угроза восстановления и/или повторного использования аутентификационной информации:

Угроза заключается в возможности доступа к данным пользователя в результате подбора (например, путём полного перебора или перебора по словарю) аутентификационной информации дискредитируемой учётной записи пользователя в системе, а также путём перехвата и повторного использования хэша пароля, для восстановления сеанса.

7. УБИ.074: Угроза несанкционированного доступа к аутентификационной информации:

Угроза заключается в возможности извлечения паролей, имён пользователей или других учётных данных из оперативной памяти компьютера или хищения (копирования) файлов паролей (в том числе хранящихся в открытом виде) с машинных носителей информации.

8. УБИ.086: Угроза несанкционированного изменения аутентификационной информации:

Угроза заключается в возможности осуществления неправомерного доступа нарушителем к аутентификационной информации других пользователей с помощью штатных средств операционной системы или специальных программных средств.

9. УБИ.090: Угроза несанкционированного создания учётной записи пользователя:

Угроза заключается в возможности создания нарушителем в системе дополнительной учётной записи пользователя и её дальнейшего использования в собственных неправомерных целях (входа в систему с правами этой учётной записи и осуществления деструктивных действий по отношению к дискредитированной системе или из дискредитированной системы по отношению к другим системам).

10. УБИ.100: Угроза обхода некорректно настроенных механизмов аутентификации:

Угроза заключается в возможности получения нарушителем привилегий в системе без прохождения процедуры аутентификации за счёт выполнения действий, нарушающих условия корректной работы средств аутентификации (например, ввод данных неподдерживаемого формата).

11. УБИ.001: Угроза автоматического распространения вредоносного кода в грид-системе:

Угроза заключается в возможности внедрения и запуска вредоносного кода от имени доверенного процесса на любом из ресурсных центров грид-системы и его автоматического распространения на все узлы грид-системы.

T4: Закрепление (сохранение доступа) в системе или сети.

Тактическая задача: получив доступ к узлу сети с помощью некоторой последовательности действий, нарушитель стремится упростить себе повторное получение доступа к этому узлу, если он ему впоследствии понадобится (например, устанавливает средства удаленного управления узлом, изменяет настройки средств защиты и другие действия).

- **T2.10:** Несанкционированный доступ путем подбора учетных данных сотрудника или легитимного пользователя (методами прямого перебора, словарных атак, паролей производителей по умолчанию, использования одинаковых паролей для разных учетных записей, применения «радужных» таблиц или другими);
- **T2.11:** Несанкционированный доступ путем компрометации учетных данных сотрудника организации, в том числе через компрометацию многократно используемого в различных системах пароля (для личных или служебных нужд);
- **T3.3:** Автоматическая загрузка вредоносного кода с удаленного сайта или ресурса с последующим запуском на выполнение;
- **T3.4:** Копирование и запуск скриптов и исполняемых файлов через средства удаленного управления операционной системой и сервисами;
- **T4.1:** Несанкционированное создание учетных записей или кража существующих учетных данных;
- **T4.2:** Использование штатных средств удаленного доступа и управления операционной системы;

12. УБИ.028: Угроза использования альтернативных путей доступа к ресурсам:

Угроза заключается в возможности осуществления нарушителем несанкционированного доступа к защищаемой информации в обход штатных механизмов с помощью нестандартных интерфейсов (в том числе доступа через командную строку в обход графического интерфейса).

13. УБИ.215: Угроза несанкционированного доступа к системе при помощи сторонних сервисов:

Угроза заключается в возможности осуществления нарушителем деструктивного программного воздействия на дискредитируемую систему с использованием сторонних легитимных сервисов (социальных сетей, мессенджеров, репозиторий кода и т. п.), используемых в качестве посредника.

T5: Управление вредоносным программным обеспечением и (или) компонентами, к которым ранее был получен доступ.

Тактическая задача: внедрив вредоносное программное обеспечение или обеспечив постоянное присутствие на узле сети, нарушитель стремится автоматизировать управление внедренными инструментальными средствами, организовав взаимодействия скомпрометированным узлом и сервером управления, который может быть размещен в сети Интернет или в инфраструктуре организации.

- **T3.14:** Планирование запуска вредоносных программ при старте операционной системы путем эксплуатации стандартных механизмов, в том числе путем правки ключей реестра, отвечающих за автоматический запуск программ, запуска вредоносных программ как сервисов и т. п.;
- **T3.15:** Планирование запуска вредоносных программ через планировщиков задач в операционной системе, а также с использованием механизмов планирования выполнения в удаленной системе через удаленный вызов процедур. Выполнение в контексте планировщика в ряде случаев позволяет авторизовать вредоносное программное обеспечение и повысить доступные ему привилегии.
- **T4.3:** Скрытая установка и запуск средств удаленного доступа и управления операционной системы. Внесение изменений в конфигурацию и состав программных и программно-аппаратных средств атакуемой системы или сети, вследствие чего становится возможен многократный запуск вредоносного кода;
- **T5.1:** Удаленное управление через стандартные протоколы (например, RDP, SSH), а также использование инфраструктуры провайдеров средств удаленного администрирования. (Атакующие могут использовать стандартные протоколы удаленного управления для получения доступа к компьютерам в грид-системе и распространения вредоносного кода);
- **T5.12:** Передача команд управления через публикацию на внешнем легитимном сервисе, таком как веб-сайт, облачный ресурс, ресурс в социальной сети и т. п. (Атакующие могут использовать внешние сервисы для публикации команд управления, которые будут исполнены на удаленных системах в грид-системе).

14. УБИ.031: Угроза использования механизмов авторизации для повышения привилегий:

Угроза заключается в возможности получения нарушителем доступа к данным и функциям, предназначенным для учётных записей с более высокими чем у нарушителя привилегиями, за счёт ошибок в параметрах настройки средств разграничения доступа. При этом нарушитель для повышения своих привилегий не осуществляет деструктивное программное воздействие на систему, а лишь использует существующие ошибки.

15. УБИ.117: Угроза перехвата привилегированного потока:

Угроза заключается в возможности осуществления нарушителем несанкционированного доступа к потоку данных, созданного приложением с дополнительными привилегиями (к привилегированному потоку данных), путём синхронного (вызов привилегированной функции, возвращающей неправильное значение) или асинхронного (создание обратных вызовов, манипулирование указателями и т. п.) деструктивного программного воздействия на него.

УБИ.118: Угроза перехвата привилегированного процесса:

Угроза заключается в возможности получения нарушителем права управления процессом, обладающим высокими привилегиями (например, унаследованными от пользователя или группы пользователей, выполняющих роль администраторов дискредитируемой системы), для выполнения произвольного вредоносного кода с правами дискредитированного процесса.

16. УБИ.122: Угроза повышения привилегий:

Угроза заключается в возможности осуществления нарушителем деструктивного программного воздействия на дискредитируемый процесс (или систему) или на другие процессы (или системы) от его (её) имени путём эксплуатации неправомерно полученных нарушителем дополнительных прав на управление дискредитированным объектом.

17. УБИ.147: Угроза распространения несанкционированно повышенных прав на всю грид-систему:

Угроза заключается в возможности автоматического распространения на всю грид-систему несанкционированно полученных нарушителем на одном узле привилегий.

18. УБИ.197: Угроза хищения аутентификационной информации из временных файлов cookie:

Угроза заключается в возможности хищения с использованием вредоносной программы аутентификационной информации пользователей, их счетов, хранящейся во временных файлах cookie, и передачи этой информации нарушителям через открытый RDP-порт.

T6: Повышение привилегий по доступу к компонентам систем и сетей.

Тактическая задача: получив первоначальный доступ к узлу с привилегиями, недостаточными для совершения нужных ему действий, нарушитель стремится повысить полученные привилегии и получить контроль над узлом.

- **T6.1:** Получение данных для аутентификации и авторизации от имени привилегированной учетной записи путем поиска этих данных в папках и файлах, поиска в памяти или перехвата в сетевом трафике. Данные для авторизации включают пароли, хэш-суммы паролей, токены, идентификаторы сессии, криптографические ключи, но не ограничиваются ими;
- **T6.2:** Подбор пароля или другой информации для аутентификации от имени привилегированной учетной записи;
- **T6.4:** Эксплуатация уязвимостей механизма имперсонации (запуска операций в системе от имени другой учетной записи). Пример: эксплуатация уязвимости штатного механизма имперсонации, реализуемого операционной системой;
- **T6.5:** Манипуляции с идентификатором сессии, токеном доступа или иным параметром, определяющим права и полномочия пользователя в системе таким образом, что новый или измененный идентификатор/токен/параметр дает возможность выполнения ранее недоступных пользователю операций. Пример: кража и подделка cookie сессии для получения авторизованного доступа к веб-интерфейсу управления сетевого устройства;
- **T6.6:** Обход политики ограничения пользовательских учетных записей в выполнении групп операций, требующих привилегированного режима. Пример: обход "User Account Control" в операционной системе Windows;
- **T6.7:** Использование уязвимостей конфигурации системы, служб и приложений, в том числе предварительно сконфигурированных профилей привилегированных пользователей, автоматически запускаемых от имени привилегированных пользователей скриптов, приложений и экземпляров окружения, позволяющих вредоносному ПО выполняться с повышенными привилегиями. Примеры: 1) использование профилей PowerShell для закрепления вредоносного ПО в системе и выполнения этого ПО с повышенными привилегиями; 2) конфигурация команды перехода в привилегированный режим sudo, при которой успешный результат выполнения этой команды на некоторое время кэшируется, что при определенных обстоятельствах может быть использовано вредоносным кодом для выполнения привилегированных операций в течение этого времени; 3) параметры исполнения файлов (Image File Execution Options, IFEO), позволяющие переключать исполнение файлов в режим отладки, выполняя вредоносные приложения под видом отладчиков и средств мониторинга, что позволяет им отключать системные приложения и средства защиты.

19. УБИ.185: Угроза несанкционированного изменения параметров настройки средств защиты информации:

Угроза заключается в возможности осуществления нарушителем несанкционированного изменения параметров настройки средства защиты информации. Данная угроза обусловлена слабостями мер разграничения доступа к конфигурационным файлам средства защиты информации.

20. УБИ.187: Угроза несанкционированного воздействия на средство защиты информации:

Угроза заключается в возможности осуществления нарушителем несанкционированного доступа к программной среде управления средством защиты информации и изменения режима его функционирования.

21. УБИ.189: Угроза маскирования действий вредоносного кода:

Угроза заключается в возможности сокрытия в системе действий вредоносного кода за счет применения специальных механизмов маскирования кода (архивирование, изменение формата данных и др.), которые препятствуют его дальнейшему анализу.

22. УБИ.191: Угроза внедрения вредоносного кода в дистрибутив программного обеспечения:

Угроза заключается в возможности осуществления нарушителем заражения системы путем установки недоверенного дистрибутива, в который внедрен вредоносный код.

23. УБИ.195: Угроза удаленного запуска вредоносного кода в обход механизмов защиты операционной системы:

Угроза заключается в возможности удаленного запуска вредоносного кода за счет создания приложений, использующих обход механизмов защиты, встроенных в операционную систему.

24. УБИ.198: Угроза скрытной регистрации вредоносной программой учетных записей администраторов:

Угроза заключается в возможности скрытного создания внедренной вредоносной программой учетных записей с правами администратора с целью последующего их использования для несанкционированного доступа к пользовательской информации и к настройкам программного обеспечения, установленного на инфицированном компьютере;

T7: Соккрытие действий и применяемых при этом средств от обнаружения.

Тактическая задача: нарушитель стремится затруднить применение мер защиты информации, которые способны помешать его действиям или обнаружить их.

- **T7.2:** Очистка/затирание истории команд и журналов регистрации, перенаправление записей в журналы регистрации, переполнение истории команд и журналов регистрации, затруднение доступа к журналам регистрации для авторизованных пользователей;
- **T7.4:** Отключение средств защиты от угроз информационной безопасности, в том числе средств антивирусной защиты, механизмов аудита, консолей оператора мониторинга и средств защиты других типов;
- **T7.10:** Внедрение вредоносного кода в доверенные процессы операционной системы и другие объекты, которые не подвергаются анализу на наличие такого кода, для предотвращения обнаружения;
- **T7.11:** Модификация модулей и конфигурации вредоносного программного обеспечения для затруднения его обнаружения в системе. Пример: внесение изменений в модули и конфигурацию вредоносного ПО для удаления индикаторов компрометации этим ВПО после обнаружения его в других системах;
- **T7.13:** Создание скрытых файлов, скрытых учетных записей;
- **T7.17:** Обфускация, шифрование, упаковка с защитой паролем или соккрытие стеганографическими методами программного кода вредоносного ПО, данных и команд управляющего трафика, в том числе при хранении этого кода и данных в атакуемой системе, при хранении на сетевом ресурсе или при передаче по сети;
- **T7.18:** Использование средств виртуализации для сокращения вредоносного кода или вредоносной активности от средств обнаружения в операционной системе;
- **T7.26:** Подмена дистрибутивов (установочных комплектов) программ на носителях информации или общих сетевых ресурсах;
- **T7.27:** Компрометация сертификата, используемого для цифровой подписи образа ПО, включая кражу этого сертификата у производителя ПО или покупку краденного сертификата на нелегальных площадках в сетях связи (т.н. «дарквеб») и подделку сертификата с помощью эксплуатации уязвимостей ПО, реализующего функции генерирования криптографических ключей, хранения и управления цифровыми сертификатами.

25. УБИ.099: Угроза обнаружения хостов:

Угроза заключается в возможности сканирования нарушителем вычислительной сети для выявления работающих сетевых узлов.

26. УБИ.104: Угроза определения топологии вычислительной сети:

Угроза заключается в возможности определения нарушителем состояния сетевых узлов дискредитируемой системы (т.н. сканирование сети) для получения сведений о топологии дискредитируемой вычислительной сети, которые могут быть использованы в дальнейшем при попытках реализации других угроз.

27. УБИ.116: Угроза перехвата данных, передаваемых по вычислительной сети:

Угроза заключается в возможности осуществления нарушителем несанкционированного доступа к сетевому трафику дискредитируемой вычислительной сети в пассивном («прослушивание» трафика) или активном (подмена пакетов, изменение их содержимого) режиме для сбора и анализа сведений (например, аутентификационной информации), которые могут быть использованы в дальнейшем для реализации других угроз, оставаясь при реализации данной угрозы невидимым (скрытым) получателем перехватываемых данных. Кроме того, нарушитель может проводить исследования других типов потоков данных, например радиосигналов.

T8: Получение доступа (распространение доступа) к другим компонентам систем и сетей или смежным системам и сетям.

Тактическая задача: получив доступ к некоторым узлам инфраструктуры, нарушитель стремится получить доступ к другим узлам. Подобное распространение доступа может быть нецеленаправленным: так, еще не зная, к каким именно компонентам инфраструктуры требуется получить доступ для того, чтобы вызвать нужные ему негативные последствия, нарушитель может стремиться получить контроль над как можно большей частью инфраструктуры систем и сетей.

- **T8.1:** Эксплуатация уязвимостей для повышения привилегий в системе или сети для удаленного выполнения программного кода для распространения доступа;
- **T8.2:** Использование средств и интерфейсов удаленного управления для получения доступа к смежным системам и сетям;
- **T8.4:** Удаленное копирование файлов, включая модули вредоносного программного обеспечения и легитимные программные средства, которые позволяют злоумышленнику получать доступ к смежным системам и сетям;
- **T8.5:** Изменение конфигурации сети, включая изменение конфигурации сетевых устройств, организацию прокси-соединений, изменение таблиц маршрутизации, сброс и модификацию паролей доступа к интерфейсам управления сетевыми устройствами;
- **T8.8:** Использование доверенных отношений скомпрометированной системы и пользователей этой системы с другими системами и пользователями для распространения вредоносного программного обеспечения или для доступа к системам и информации в других системах и сетях. Пример: отсылка сообщений корпоративной электронной почты от имени коллег и прочих доверенных лиц.

28. УБИ.088: Угроза несанкционированного копирования защищаемой информации:

Угроза заключается в возможности неправомерного получения нарушителем копии защищаемой информации путём проведения последовательности неправомерных действий, включающих: несанкционированный доступ к защищаемой информации, копирование найденной информации на съёмный носитель (или в другое место, доступное нарушителю вне системы);

29. УБИ.111: Угроза передачи данных по скрытым каналам:

Угроза заключается в возможности осуществления нарушителем неправомерного вывода защищаемой информации из системы, а также передаче управляющих команд путём её нестандартного (незаметного, скрытого) размещения в легитимно передаваемых по сети (или сохраняемых на отчуждаемые носители) открытых данных путём её маскирования под служебные протоколы, сокрытия в потоке других данных (стеганография), использования скрытых пикселей («пикселей отслеживания») и т. п.;

T9: Сбор и вывод из системы или сети информации, необходимой для дальнейших действий при реализации угроз безопасности информации или реализации новых угроз.

Тактическая задача: в ходе реализации угроз безопасности информации, нарушителю может потребоваться получить и вывести за пределы инфраструктуры большие объёмы информации, избежав при этом обнаружения или противодействия.

- **T9.2:** Доступ к системе для сбора информации и вывод информации через использование штатных средств удаленного доступа и управления операционной системы;

- **T9.4:** Вывод информации на нестандартные порты на внешних серверах, что в некоторых случаях позволяет эксплуатировать уязвимости средств сетевой фильтрации для обхода этих средств;
- **T9.5:** Отправка данных по известным протоколам управления и передачи данных;
- **T9.7:** Проксирование трафика передачи данных для маскировки подозрительной сетевой активности, обхода правил на межсетевом экране и сокрытия адресов инфраструктуры нарушителей, дублирование каналов связи, обфускация и разделение трафика передачи данных во избежание обнаружения. Примеры: 1) использование скомпрометированных систем в той же сети, для которых правилами МЭ разрешен доступ в Интернет в качестве прокси серверов; 2) использование инфраструктуры сети TOR для проксирования запросов к серверам управления; 3) использование одного коммуникационного протокола для запроса, и другого – для ответа на запрос;
- **T9.8:** Туннелирование трафика передачи данных через VPN;
- **T9.12:** Шифрование выводимой информации, использование стеганографии для сокрытия факта вывода информации;
- **T9.14:** Вывод информации путем размещения сообщений или файлов на публичных ресурсах, доступных для анонимного нарушителя (форумы, файлообменные сервисы, фотобанки, облачные сервисы, социальные сети).

30. УБИ.170: Угроза неправомерного шифрования информации:

Угроза заключается в возможности фактической потери доступности защищаемых данных из-за их несанкционированного криптографического преобразования нарушителем с помощью известного только ему секретного ключа.

31. УБИ.183: Угроза перехвата управления автоматизированной системой управления технологическими процессами:

Угроза заключается в возможности осуществления нарушителем несанкционированного доступа к информационной инфраструктуре за счёт получения нарушителем права управления входящей в её состав автоматизированной системой управления технологическими процессами путём эксплуатации уязвимостей её программного обеспечения или слабостей технологических протоколов передачи данных.

32. УБИ.212: Угроза перехвата управления информационной системой:

Угроза заключается в возможности осуществления нарушителем несанкционированного доступа к информационным, программным и вычислительным ресурсам информационной системы в результате подмены средств централизованного управления информационной системой или её компонентами.

T10: Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям.

Тактическая задача: достижение нарушителем конечной цели, приводящее к реализации моделируемой угрозы и причинению недопустимых негативных последствий.

- **T10.6:** Несанкционированное воздействие на программный код, конфигурацию и параметры доступа прошивки устройства;
- **T10.8:** Уничтожение информации, включая информацию, хранимую в виде файлов, информацию в базах данных и репозиториях, информацию на неразмеченных областях дисков и сменных носителей;
- **T10.10:** Организация отказа в обслуживании одной или нескольких систем, компонентов системы или сети;
- **T10.11:** Нецелевое использование ресурсов системы. Примеры: 1) организация майнинговой платформы; 2) организация платформы для осуществления атак отказа в обслуживании на смежные системы и сети.

Для удобства предоставления результатов анализа мы представим ответ в виде таблицы, содержащей следующую информацию:

- 1. **Номер Т:** порядковый номер тактики, используемой для построения сценариев угроз безопасности;
- 2. **Номер из БДУ ФСТЭК:** уникальный идентификатор угрозы в базе данных угроз ФСТЭК России;
- 3. **Наименование угрозы безопасности информации:** краткое описание угрозы безопасности информации, которая может быть актуальной для организации;
- 4. **Сценарии реализации угроз:** коды сценариев, указанных в методике определения угроз ФСТЭК, которые позволяют реализовать данную угрозу в информационной системе организации;

Таблица позволит нам систематизировать и предоставить результаты анализа актуальных угроз безопасности информации, которые могут стать основой для дальнейшего разработки мер по обеспечению информационной безопасности в организации.

№ Т	Номер из БДУ ФСТЭК	Наименование угрозы безопасности информации	Сценарии реализации угроз (допускается использовать коды из методики определения угроз)
1	УБИ.098	Угроза обнаружения открытых портов и идентификации привязанных к ним сетевых служб	T1.3, T1.4
2	УБИ.073	Угроза несанкционированного доступа к активному и (или) пассивному виртуальному и (или) физическому сетевому оборудованию из физической и (или) виртуальной сети	T2.1, T2.3, T2.4, T2.5, T2.8, T2.10
	УБИ.030	Угроза использования информации идентификации/аутентификации, заданной по умолчанию	
	УБИ.192	Угроза использования уязвимых версий программного обеспечения	
3	УБИ.006	Угроза внедрения кода или данных	T3.1, T3.2, T3.4
4	УБИ.008	Угроза восстановления и/или повторного использования аутентификационной информации	T2.10, T2.11, T3.3, T3.4, T4.1, T4.2
	УБИ.074	Угроза несанкционированного доступа к аутентификационной информации	
	УБИ.086	Угроза несанкционированного изменения аутентификационной информации	
	УБИ.090	Угроза несанкционированного создания учётной записи пользователя	
	УБИ.100	Угроза обхода некорректно настроенных механизмов аутентификации	
	УБИ.001	Угроза автоматического распространения вредоносного кода в грид-системе	
5	УБИ.028	Угроза использования альтернативных путей доступа к ресурсам	T3.14, T3.15, T4.3, T5.1, T5.12
	УБИ.215	Угроза несанкционированного доступа к системе при помощи сторонних сервисов	
6	УБИ.031	Угроза использования механизмов авторизации для повышения привилегий	T6.1, T6.2, T6.4, T6.5, T6.6, T6.7
	УБИ.117	Угроза перехвата привилегированного потока	
	УБИ.118	Угроза перехвата привилегированного процесса	
	УБИ.122	Угроза повышения привилегий	
	УБИ.147	Угроза распространения несанкционированно повышенных прав на всю грид-систему	
	УБИ.197	Угроза хищения аутентификационной информации из временных файлов cookie	
7	УБИ.185	Угроза несанкционированного изменения параметров настройки средств защиты информации	T7.2, T7.4, T7.10, T7.11, T7.13, T7.17, T7.18, T7.26, T7.27
	УБИ.187	Угроза несанкционированного воздействия на средство защиты информации	
	УБИ.189	Угроза маскирования действий вредоносного кода	
	УБИ.191	Угроза внедрения вредоносного кода в дистрибутив программного обеспечения	
	УБИ.195	Угроза удаленного запуска вредоносного кода в обход механизмов защиты операционной системы	
	УБИ.198	Угроза скрытной регистрации вредоносной программой учетных записей администраторов	

№ Т	Номер из БДУ ФСТЭК	Наименование угрозы безопасности информации	Сценарии реализации угроз (допускается использовать коды из методики определения угроз)
8	УБИ.099	Угроза обнаружения хостов	Т8.1, Т8.2, Т8.4, Т8.5, Т8.8
	УБИ.104	Угроза определения топологии вычислительной сети	
	УБИ.116	Угроза перехвата данных, передаваемых по вычислительной сети	
9	УБИ.088	Угроза несанкционированного копирования защищаемой информации	Т9.2, Т9.4, Т9.5, Т9.7, Т9.8, Т9.12, Т9.14
	УБИ.111	Угроза передачи данных по скрытым каналам	
10	УБИ.170	Угроза неправомерного шифрования информации	Т10.6, Т10.8, Т10.10, Т10.11
	УБИ.183	Угроза перехвата управления автоматизированной системой управления технологическими процессами	
	УБИ.212	Угроза перехвата управления информационной системой	

ЗАКЛЮЧЕНИЕ

В ходе нашей практической работы мы провели анализ актуальных угроз безопасности информации для коммерческой организации, занимающейся грузоперевозками. Данный анализ позволил нам идентифицировать разнообразные угрозы, которым может быть подвержена организация в связи с ее деятельностью.

Мы перечислили тактики и техники, с помощью которых эти угрозы могут быть реализованы, что поможет организации лучше понять, каким образом может быть осуществлено нарушение безопасности информации и какие меры предпринять для предотвращения и выявления таких атак.

Сформировали таблицу угроз безопасности информации и связанных с ними тактик и техник. Такая таблица поможет организации разработать соответствующие меры безопасности и стратегии защиты, а также обучить своих сотрудников узнавать и предотвращать угрозы.

Важно отметить, что безопасность информации является непрерывным процессом, и организации должны постоянно совершенствовать свои меры защиты в ответ на появляющиеся новые угрозы и техники атаки. Эффективная защита информации требует комплексного подхода, включая технические, организационные и человеческие аспекты безопасности.

Рекомендуется регулярно обновлять и пересматривать таблицу угроз безопасности информации, чтобы отслеживать изменения в угрозах и дополнять ее новыми тактиками и техниками, а также адаптировать применяемые меры безопасности в соответствии с новыми вызовами и тенденциями в области кибербезопасности.

В итоге наша практическая работа предоставила ценную информацию, которая поможет коммерческой организации, повысить уровень безопасности информации, защитить свою инфраструктуру и данные от возможных угроз, и обеспечить надежную и безопасную работу своих систем и сетей.

ПРАКТИЧЕСКАЯ РАБОТА ЗАВЕРШЕНА!

MIFIIB-01.08.2023